

See discussions, stats, and author profiles for this publication at: <https://www.researchgate.net/publication/343373756>

Survey on DNS-Specific Security Issues and Solution Approaches

Chapter · January 2021

DOI: 10.1007/978-981-15-5309-7_9

CITATIONS

12

READS

865

3 authors, including:



[Usman Aijaz](#)

Brindavan College

4 PUBLICATIONS 22 CITATIONS

SEE PROFILE

Survey on DNS Specific Security Issues and Solution Approach

Usman Aijaz N
Brindavan College of Engineering,
Bangalore.
Email: uaijaz9@gmail.com

Mohammed Misbahuddin.
Centre for Development of Advanced Computing
Bangalore
Email: misbah@cdac.in

Abstract - The domain name system (DNS) is the most essential part of primary internet infrastructure that translates hostnames to IP addresses. DNS server is available to all users to resolve their hostnames. They are not configured with any administrative control. DNS is an open resolver so that it is a hot cake for attackers to perform various attacks such as cache poisonings, DOS and DDOS attacks. DNS only converts domain names to their matching IP addresses without providing any protection when sending messages. The man-in-the-middle can easily snoop into the insecure channel and can get the user's sensitive information. Due to this drawback of DNS, we came across another more secure layer of DNSSEC. DNSSEC uses certificates to authenticate the servers, hence, more secure than DNS. It protects the DNS from other vulnerabilities as well. However, DNSSEC has its security concerns like confidentiality, packet fragmentation, amplification attack and mainly it is a strong source of a DDOS attack. In this paper, we discuss how to increase the security of DNSSEC protocol by adding an extra layer of security using the EV-SSL certificate to overcome DNS security threats.

Keywords: DNS, DOS, DDOS, DNSSEC, EV-SSL.

1. INTRODUCTION

On the internet, every computer that is connected to it is uniquely identified by the address known as Internet Protocol Address or IP address, to recognize and get to it. These IP addresses are 32-bit numbers which are extremely hard to remember. As a human being, we can easily remember names compared to numerical. To overcome the difficulty and to access any system on the internet through name instead of its IP address, a service is provided by the Internet and it is called a Domain name system. DNS provides a means to map IP addresses to names. Without DNS, we would have to remember that 'www.amazon.com' is the IP address 72.21.207.65, which is very difficult. DNS is the most successful and largest distributed hierarchical database as shown in figure 1.

If a client wants to know the IP address for the hostname www.example.com, the client first accesses one of the root servers that does not have the IP address of www.example.com so it gives the IP address of the TLD servers, then the client contacts one of the TLD servers. The TLD server yields the IP address of an authoritative server, for example.com, the client contacts one of the authoritative servers, which returns the IP address of the hostname.

www.example.com this may happen either iteratively or recursively. If it is recursive then the burden of finding the IP address of a domain name is on Root DNS and if it is iterative then local DNS performs the relevant task.

In recent years, a large number of DNS attacks have been discovered such as Man in the Middle, NXDomain, DNS ID Spoofing attacks, Malware, phishing, DOS & DDOS attacks, cache poisoning attack, information leakage attack, etc. These attacks lead to very serious consequences. Some are simple like making a service unapproachable for example, a site isn't available and some are risky like diverting to an inappropriate site through which attackers can pick up and get to our confidential information such as passwords, credit/debit PINs and bank account details that may prompt tremendous money related misfortune.

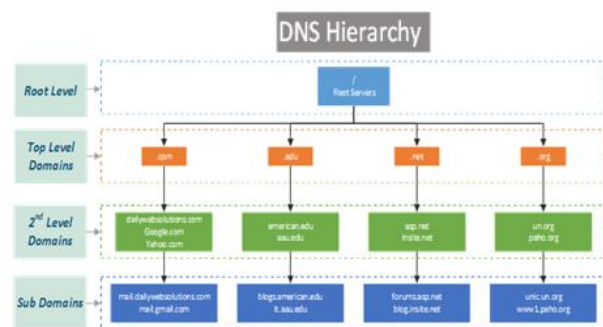


Figure1: DNS Distributed hierarchical database [1].

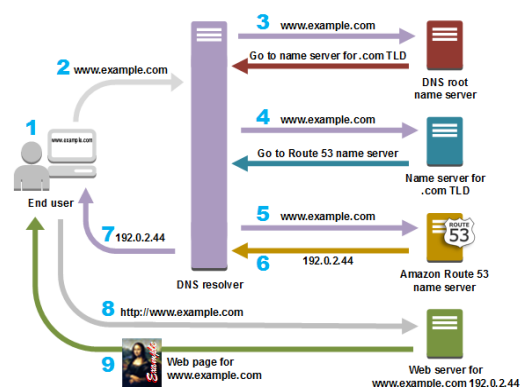


Fig 2: Working of DNS [2].

2. DNS AND SECURITY THREATS RELATED TO DNS.

DNS is an open resolver that is available to provide name resolution to all clients regardless of their domain. They are not designed with any managerial control. open resolver is on the hotcake for attackers and may be susceptible to mischievous activities and DNS cache poisoning attacks, DOS / DDoS attacks, Malware (malicious software), phishing, Resource utilization attacks, and DNS ID Hacking, etc against DNS server [3]. Some of these attacks are discussed in this section.

2.1. DNS Cache poisoning attack.

Here DNS is allowed to store malicious data by the hackers, which results in the wrong mapping of URL to an IP address of the authoritative server which is under the control of hackers [5]. For instance, bogus addresses for some.bank.com or any agency's site harmed with the IP address of web server controlled by hackers, where hackers facilitated a digitally indistinguishable replica of the original site and all clients will be a phony victim to cache poisoning attacks. The end clients are defrauded for login, password, and account information credit card numbers, etc. This information will be recorded and utilized later on by attackers.

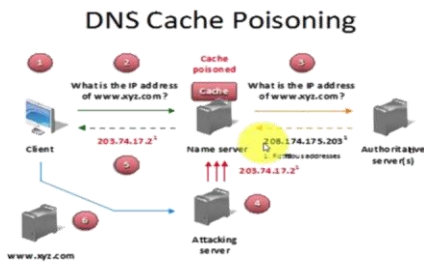


Figure 3:DNS Cache Poisoning attack[4].

2.2 DOS/ DDoS attack.

The DOS attack commonly makes use of one PC and one Internet connection to flood a targeted machine or resource whereas DDoS attack makes use of many PCs and Internet connections to flood the targeted resource. DOS it intends to make the web in a region deadened or to make some site difficult to reach former attack ISP recursive name server while the later target domain authorization server [5].DOS attacks comprise of exceptionally damageable attacks to downfall or degrade the quality of service in a barely unforeseen method [6]. While a DDoS attack is an endeavor to flood a victim through producing a volume of traffic by an enormous number of machine [7,8] DDoS attack utilizes a countless number of negotiated hosts called Zombies or Bots that are gathered from insecure PCs that entrance the web through high-speed connections by using malicious software on the insecure PCs. These hosts are then gathered to shape one huge network named a Botnet that is anticipating only a command from the attackers who may have different motivations to launch a DDoS attack.

DDoS flooding attacks can be classified into two categories named as

- A) Network /Transport level DDOS Flooding attacks.
- B) Application-level DDOS Flooding attacks.

2.2.A. Network/transport-level DDoS flooding attacks:

These flooding attacks propelled using TCP, UDP, ICMP, and DNS protocol packets[6]. Attacks under this category are as shown in figure 4.

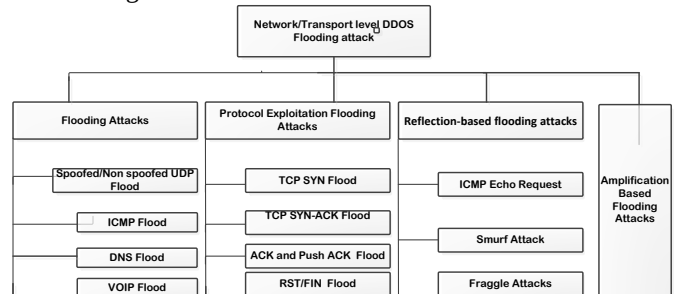


Fig 4: Network /Transport level DDOS Flooding attacks.

2.2.B. Application-level DDoS flooding attacks:

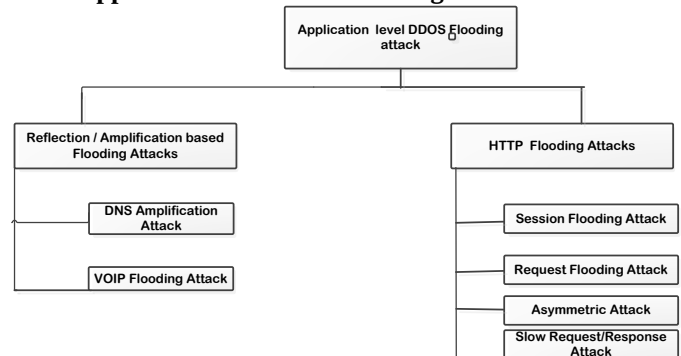


Fig 5: Application-level DDOS Flooding attacks.

2.3. Spoofing

A spoofing attack may be a condition during which an individual or program can effectively pretend as another by misrepresenting information, to realize an illegitimate advantage. Many communication channels do not have mechanisms for authenticating the message to know whether it is from source or destination, and thus, are susceptible to spoofing attacks when additional precautionary measures are not taken by applications to authenticate the identity of the sending or receiving host. An example of spoofing is where the man-in-the-middle pretends to be the sender and then sniffs through the packets, modifies them and ultimately sends the modified messages to the receiver. Spoofing can also be the case when the attacker sniffs the packets and reads/modifies the sensitive personal information.

2.4. Phishing

Phishing is a fraudulent attack used to steal user confidential information like login credentials and credit/debit card numbers. It is often used for malicious reasons, by impersonating as a reliable entity in an electronic

communication. It is carried out by email spoofing or instant messaging. This kind of attack usually redirects users to enter their confidential information at a bogus site controlled by the attackers. These sites look identical to a legitimate website due to which it is very difficult for the user to identify them as fake.

An example of phishing is where the victim opens a website which is a fake one but looks exactly like a legitimate one. In this case, the victim enters his/her personal sensitive information which is obtained by the attacker, hence, using those details to hack or modify other accounts.

2.5. Identity theft

Identity theft is the intentional use of somebody else's identity, as a method to obtain financial gain or to obtain credit and other benefits in the name of another person, and perhaps for the loss or harm of another person. Identity theft occurs when a person uses personally-detecting information of someone else, such as their name, identification number, or credit card number, without their consent, to commit fraud or other crimes. Identity theft can occur when the attacker uses the victim's personal information to access financial benefits or for some other offense. In this case, the victim is not known whether her identity has been stolen. The attacker very cleverly steals the identity of the users.

2.6. Forgery

It is the process of creating, molding or imitating objects, figures, or documents with the intention of cheating or changing the public perception to make a profit by selling a counterfeit item [12]

2.7. Eavesdropping

Listening to others privately or secretly without their consent. Network eavesdropping is a network layer attack, which emphasizes capturing small packets from networks transferred by other computers and reading data content in pursuit of certain types of information. This type of network attack is one of the most effective due to the lack of commonly used encryption services. It is also linked to a collection of metadata. These types of attacks are usually performed by Black Hat hackers; On the other hand, even government agencies, such as the National Security Agency are also involved[12].

2.8. Packet sniffing

Sniffing is a function through which a person can capture packets of data flowing over a computer network. The software or device that performs this task is called a packet sniffer. By using a packet sniffer it is possible to capture passwords, IP addresses, protocols and other information on the network which will help the attacker to intrude the network. All network data travels across the Internet and then into and out of PCs as an individual, variable-size data packets. Since the typical PC user never sees this raw data, many spyware systems secretly send superficial information from the user's computer without their realization [12]

2.9. Tampering

Purposeful alteration of products in a way that would make them harmful to the consumer. Packet tampering involves deliberately modifying the contents of packets through the

unauthorized channel as they travel over the Internet or exchange data on computer disks after entering a network. For example, an attacker might place a tap on the network line to capture packets as they leave the computer. The attacker can leave the network or change the information. Unfortunately, attributing a missing packet to a malicious action is quite challenging because normal network congestion can cause the same effect. Modern networks normally drop packets when the load temporarily surpasses their buffering limits [12]

2.10. Man-in-the-middle attack

MITM is an attack where an attacker intercepts communications between two parties either to secretly eavesdrop or modify traffic traveling between them and they believe that they are communicating directly to each other. An example of intermittent attacks is active eavesdropping, in which the attacker forms an independent connection with the victim machine and sends a message between them to convince that they are talking directly to each other in a private connection, whereas the entire discussion is controlled by the attacker. As an attack that aims to circumvent mutual authentication, or in the absence of it, a mid-range attack can only succeed if the attacker executes each endpoint as expected from valid ends to their satisfaction. Can do. Most cryptographic protocols such as TLS are the best way to help protect against MitM attacks. TLS can authenticate one or both parties using a mutually trusted certificate authority.[12]

3. SOLUTION TO DNS SECURITY THREATS.

3.1. DNSSEC (DNS Security Extension)

DNSSEC (DNS Security Extension) as defined in [RFC4033-4035], proposed and standardized in 1997, resolves some security issues associated with DNS protocols. DNSSEC protects data sent by DNS servers against fraud. This ensures two security objectives, such as authentication and integrity of the data source. DNSSEC makes stronger authentication in DNS using digital signatures based on public-key cryptography. With DNSSEC, it's not DNS queries and responses themselves that are cryptographically signed, but rather DNS data itself is signed by the proprietor of the data[18]. Thus, a suspicious DNS client can retrieve the signature and, using the server's key, it can check the correctness of the data.

DNSSEC secures zone files using cryptography. Therefore, each zone has at least one pair of the key. The child zone's public key is signed by the private key of the parent zone, parting only the root that is signed itself. This method creates a trust chain (chain of trust). According to Shulman and Wadner, Domain Name System Security Extensions (DNSSEC) standards such as RFC4033, RFC4034, and RFC4035 are intended to address the issue of cache poisoning in DNS, through data integrity and original authenticity via a cryptographic digital signature over DNS Resource records.

3.2 SSL CERTIFICATES

These Certificates are small-sized files that digitally bind a cryptographic key to an organization's information like hostname, server name or domain name and organizational uniqueness and geographical locality of the organization. When installed on a web server, it allows the lock and the https protocol. This allows secure connections between a web server and a browser. Typically, SSL is used to secure logins, data transfer, and credit card transactions.

An organization wants to install the SSL Certificate onto its web server to initiate a secure reliable session with web browsers. Once a secure session is made, all web traffic links between the web server and the web browser will become secure and reliable. When the SSL certificate is properly connected to the server, the application protocol known as HTTP will change to HTTPS, where 'S' means 'secure'. Depending on the type of certificate purchased for the website and which browser is being used to surf the Internet, a browser will show a padlock or green bar in the browser search bar before the website link, when someone visits a website that has an SSL Certificate installed.

A green locked padlock indicates that the website is secure under HTTPS and if there is a red unlocked padlock symbol it shows that that website is not secured under HTTPS.

SSL Certificates are also known as public-key cryptography certificates PKC. This type of cryptography has the power of two keys that are long strings of randomly generated numbers. One is called a private key, the other is the public key. The server knows the public key and is available in the public domain and which can be used to encrypt the messages. It uses asymmetric public-key encryption and decryption process. For example, if Alice sends a message to Bob, she locks it with Bob's public key, but the only way to decrypt it is to unlock it with Bob's private key. Bob is the only person with his private key so Bob can only use it to unlock Alice's message. If a hacker blocks before Bob unlocks it, they get a cryptographic code, which they can't break without Bob's private key, which is very secure and hidden[14].

Advantages of An SSL Certificate are[17]:

- SSL Increase Customer Trust & Revenue
- Increases your Google Rankings
- Protects from Google Warning
- SSL Protects from Phishing and other Attacks

3.3 Extended Validation Certificate

The EV SSL (Extended Validation SSL) certificate is the highest form of SSL certificate available on the market so far [14]. Websites phishing, or fraudulent or identity theft, continue to pose a foremost threat to legitimate/authentic websites and online services. phishes began using certificates to trick their victims into viewing their sites more faithfully and submitting their financial or personal data. EV SSL can help solve this problem by bringing the site operator's verified identity to the front and center of the website - displaying it directly in the address bar making verification user-friendly and easy on the client-side.

Extended Validation (EV) SSL Certificates:



Standard SSL Certificates (such as GlobalSign DomainSSL and OrganizationSSL) display:



Figure 6: Difference between SSL certificate and EV SSL certificate [15]

4. BENEFITS ON DNSSEC AND SSL

Complete use of DNSEC will ensure that the end-user is connected to the true web site or other service corresponding to a particular domain name. Although this will not cater to all the security issues of the DNS, it does protect a critical part of it - the directory lookup -complementing it with other technologies such as SSL that protects the "conversation", and provide a platform for yet to be developed security improvements.

4.1. FORGERY

In the DNS lookup, the user computer is not always waiting for the address of www.example.com. Hence, the hacker has to schedule his forgeries such that they arrive when a user computer is waiting for the reply. There are several definite ways for the hacker to do forgery of data supplied over the internet. Some of them are-

- Attack repeatedly by sending a forged packet one after another. As a result the probability of arriving one of the forgeries at the right time increases.
- Hacker can poke user PC to trigger/start a known DNS lookup at a known time.
- user computer stores incoming DNS results for queries in a cache and reuses those results for a while for faster navigation using this as a plus point a hacker caches the DNS records in advance and redirects the user to malicious websites.
- In all of this, the hacker must win the race against the legitimate/standard DNS response from the example.com administrator. If the user receives a standard DNS response before the duplicate response, it stops listening and then ignores the duplicate response received.
- HTTPS says it protects the user from fake websites. Suppose a hacker duplicates a DNS response. The user's computer connects to the hacker's web server. But HTTPS warns the user about the "invalid

certificate" and avoids displaying fake web pages. But unfortunately, HTTPS still hasn't shown him the right web page.

- In short, HTTPS protects the integrity of web pages, not availability. It also has usage issues that prevent it from being used on most of the web pages.
- The Example.com administrator uses public-key cryptography to sign his DNS records stored in DNS zone files. If a hacker forges a DNS packet, the user's PC will see that the forgery is not an authentication / valid signature, and the duplicate DNS data will be lost and the user will not see the duplicate / hacked web pages. However, DNSSEC does not get the correct DNS information and as a result, we do not get the correct web page but this does not mean that DNSSEC is functionally equivalent to HTTPS. Using HTTPS Against hackers who forge DNS packets and use DNSSEC against those who duplicate HTTP packets, the DNS packet only protects attackers from duplicating DNS packets.
- Therefore, using DNS in conjunction with HTTP or HTTPS is not protected from duplicate web pages. But using DNSEC with HTTP or HTTPS can protect against duplicate web pages but at the cost of rejecting the service.

4.2. TAMPERING: it is an intentional modification of products in a way that would make them harmful to the consumer. Tampering of packets comprises changing the contents of packets as they move from one point to another over the Internet or modifying data on computer disks after penetrating a network as they travel the communication links over the network. For example, an attacker might place a tap on a network line to capture packets as they leave the computer. The attacker could eavesdrop or alter the information as it leaves the network [12]. A hacker can tamper the DNS records or the data being transferred over the channel to redirect the user to the malicious website. But to tamper the DNS records stored a hacker must introduce false records in the DNS resource records but they won't be signed by the zone hence will get filtered out. Also, the data traveling through the communication links cannot be changed as the SSL connection is running on the server.

4.3. CACHE POISONING ATTACK: Cache poisoning is a type of DNS attack in which an attacker tries to insert fraudulent data into the cache database of the Domain Name System (DNS) server. Due to which DNS server redirects the user to a malicious IP address controlled by the attacker.

An example of DNS cache poisoning is where hackers swap a genuine IP address in the DNS cache with an IP address they control. Users fetching information from this DNS cache are forwarded to the hacker's compromised site. The redirected site may be a malware download site or one designed to collect confidential information.

Another way of preventing cache poisoning is by adding security to the DNS using tools such as DNSSEC. Secure DNS (DNSSEC) uses cryptographic digital signatures signed with a trusted pair of the public key(s)/private key(s) and these certificates are stored in the zone files to validate the legitimacy and integrity of the information. The attacker cannot forge the digitally signed certificates and hence, DNS cache poisoning is prevented.

4.4. EAVESDROPPING: Listening privately or Secretly to others without their consent. Network eavesdropping is a network layer attack, which focuses on capturing small packets from networks transmitted by other computers and reading data content in search of some type of information is cured using SSL as encrypted data is transferred over network links which cannot be decrypted by the hacker hence they don't know what messages are exchanged between the end entities and therefore cannot alter them.

CONCLUSION

Denial of service attack and especially Distributed DOS attacks are dangerous for the Internet and web services. According to the surveys, the percentage of attacks is at an exponential rise with new and sophisticated techniques. In this paper, we discussed DNS and its security threats like Cache poisoning, DOS and DDOS attacks, Spoofing, Phishing, Identity theft, Forgery, etc. To secure DNS IETF added extensions to it known as DNSSEC. DNS together with HTTP or HTTPS cannot protect against fake web pages. But using DNSSEC with either HTTP or HTTPS can protect against fake web pages but with a cost of denial of service. DNSSEC uses cryptographic digital signatures signed with a trusted pair of the public key(s)/private key(s) and these certificates are stored in the zone files to authenticate the authenticity and integrity of the information. The attacker cannot forge the digitally signed certificates and hence, DNS Cache poisoning is prevented. Although using DNSSEC over DNS cures a lot of DNS security problems but they are still some security issues left that cannot be cured using DNSEC. They are phishing, spoofing and man-in-the-middle attack and DDOS attacks.

REFERENCES

- [1]. <https://medium.com/tokendaily/handshake-ens-and-decentralized-naming-services-explained-2e69a1ca1313>.
- [2]. <https://aws.amazon.com/route53/what-is-dns/>.
- [3]. M. H. Jalalzai, W. B. Shahid and M. M. W. Iqbal, DNS Security Challenges and Best Practices to Deploy Secure DNS with Digital Signatures. Proceedings of 2015 12th International Bhurban Conference on Applied Sciences & Technology (IBCAST) Islamabad, Pakistan, 13th – 17th January 2015.
- [4]. <https://www.javahaxor.org/2018/07/dns-poisoning-attack.html>.
- [5]. Futai Zou, Siyu Zhang, Li Pang, Linsen Li, Jianhua Li, Bei Pei, "survey on DNS Security."2016 IEEE Icon Data science in cyberspace.
- [6]. B. Todd, Distributed Denial of Service Attacks, Feb. 18, 2000,[online]http://www.linuxsecurity.com/resource files/intrusion

detection/ddos-whitepaper.html.

- [7] T. Peng, C. Leckie, and K. Ramamohanarao, Survey of network-based defense mechanisms countering the DoS and DDoS problems, *ACM Comput. Surv.* 39, 1, Article 3, April 2007.
- [8] U. Tariq, M. Hong, and K. Lhee, A Comprehensive Categorization of DDoS Attack and DDoS Defense Techniques, *ADMA LNAI* 4093, pp.1025-1036, 2006.
- [9] C. Douligieris, and A. Mitrokotsa, DDoS attacks and defense mechanisms: classification and state-of-the-art, *Computer Networks*, Vol.44, No. 5, pp. 643-666, April 2004.
- [10] S. Ranjan, R. Swaminathan, M. Uysal, and E. Knightly, DDoS-Resilient Scheduling to Counter Application Layer Attacks under Imperfect Detection, *IEEE INFOCOM'06*, 2006.
- [11]. J. Mirkovic and P. Reiher, "A taxonomy of DDoS attack and DDoS defense mechanisms," *ACM SIGCOMM Computer Communications Review*, vol. 34, no. 2, pp. 39-53, April 2004.
- [12] Wikipedia. [Online].Available: <https://en.wikipedia.org>
- [13] S. T. Zargar, J. Joshi, and D. Tipper, "A survey of defense mechanisms against distributed denial of service (DDoS) flooding attacks," *IEEE Communications Surveys and Tutorials*, vol. 15, no. 4, pp. 2046–2069, 2013.
- [14] GlobalSign GMO INTERNET GROUP, "SSL Information Center".[Online].Available: <https://www.globalsign.com/en/ssl-informationcenter/what-is-an-ssl-certificate/>.
- [15] R. Arends, R. Austein, M. Larson, D. Massey and S. Rose, DNS Security Introduction and Requirements, RFC 4033, Mar. 2005.
- [16] H. Shulman and M. Waidner, "Towards Forensic Analysis of Attacks with DNSSEC," *Proceeding SPW '14 Proceedings of the 2014 IEEE Security and Privacy Workshops IEEE Security and Privacy Workshops*, May 17 - 18, 2014. pp. 69-76.
- [17] <https://www.https.in/blog/the-benefits-of-ssl-certificate/>.
- [18] <https://www.icann.org/resources/pages/dnssec-what-is-it-why-important-2019-03-05-en>